



MYLESCORP TECHNOLOGIES LTD

MylesNet

Multi Tenant ISP and RADIUS SaaS

Technical Specification v3

Document control	Value
Classification	Internal Confidential
Owner and author	Jonathan Myles
Company	MylesCorp Technologies Ltd
Status	Proposed canonical v3 pending approval
Date	8 September 2026
Implementation baseline	C:\Users\Admin\Projects\mylesnet-dashboard

This specification defines the production transition of the active MylesNet dashboard into a full multi-tenant ISP and RADIUS SaaS.

Table of Contents

Select a section to navigate in compatible PDF readers. The bookmark pane also contains the document structure.

1. Executive overview
2. Document control and governing decisions
3. Product scope and outcomes
4. Current implementation evidence and gap assessment
5. Multi tenant architecture and data isolation
6. In place transition and cutover controls
7. Panel and route architecture
8. WorkOS identity and authorization
9. Tenant onboarding and readiness wizard
10. Device, NAS, router and access point onboarding
11. RADIUS AAA and service policy
12. Availability, security and abuse controls
13. Subscriber lifecycle and self service
14. Billing, payments and revenue control
15. Support, communication, reporting and APIs
16. Production technology stack and deployment boundaries
17. Data governance, observability and operations
18. Delivery phases, tests and release gates
19. Risks, dependencies and final summary
20. Detailed functional module catalogue
21. RBAC permissions and scope matrix
22. Data domain and tenant ownership inventory
23. End to end workflows and state machines
24. API, webhook and worker contract requirements
25. Detailed acceptance criteria and operational controls

1. Executive overview

MylesNet is the MylesCorp Technologies Ltd platform for independent internet service providers, WiFi operators, estates, hospitality venues, community networks, and small WISPs. The product moves the current MylesNet dashboard from a single platform and market operating model to a secure multi-tenant SaaS. Each ISP is a tenant. A tenant owns its staff, subscribers, services, devices, financial records, network policies, and operational data while MylesCorp retains a tightly controlled platform and shared-network operations boundary.

The target is an end-to-end ISP operating system, not a router dashboard or a standalone RADIUS server. It combines tenant lifecycle management, subscriber identity and services, FreeRADIUS AAA, accounting, network policy, device onboarding, payments, notifications, support, reports, and customer self-service. The system will begin with PPPoE and MikroTik Hotspot, direct M-Pesa Daraja, and the operational modules necessary to collect revenue and operate access safely. Advanced device automation, GIS, mobile workflows, AI, and high-volume analytics are deliberately phased behind proof of need.

This document is a proposed canonical v3 specification. It becomes the product source of truth only after Jonathan Myles approves it. It replaces prior v2 planning as the governing design for the in-place transition of the active dashboard repository. It does not make a production readiness claim. Every current-state statement is classified as verified, historical, unverified, planned, or approval-gated.

2. Document control and governing decisions

Owner and author: Jonathan Myles, Founder and CEO, MylesCorp Technologies Ltd. Classification: Internal Confidential. Audience: product leadership, engineering, network operations, security, finance, approved implementation partners, and reviewers. This document is retained as Markdown, DOCX, and PDF so that the vault remains the planning record and the repository retains a build-facing reference.

The following decisions are locked for this v3 proposal: the active C:\Users\Admin\Projects\mylesnet-dashboard repository is the in-place transition baseline; the existing estate will be converted through controlled checkpoints rather than parallel migration; WorkOS AuthKit is the only identity provider; WorkOS uses three organization scopes consisting of MylesNet Platform, MylesNet Network, and one organization per ISP tenant; and launch panels are Platform, Admin, Dashboard including subscriber portal, and Reseller. Agency and Partner are designed but feature-gated.

The target domain is intentionally represented as <product-domain>. A production hostname, payment credentials, provider contracts, exchange-rate provider, exact SMS and email providers, legal retention periods, and external RADIUS node addresses are not assumed. They are implementation gates that require approved configuration and evidence.

3. Product scope and outcomes

MylesNet will give an ISP a single operating workspace to onboard staff and devices, manage subscribers and service plans, collect payments, govern access, diagnose active sessions, respond to support cases, and report on revenue and network service. Its central outcome is reliable paid access: a verified payment or approved change updates entitlement, creates a durable network job, updates the RADIUS policy, performs CoA or disconnect where appropriate, verifies the result, and informs the subscriber.

The product supports residential, business, campus, hospitality, and reseller customer models. A subscriber can have contacts, locations, services, credentials, devices, invoices, payments, tickets, communication preferences, and a complete audited timeline. A tenant can have markets, sites, branches, brands, currencies, taxes, staff roles, agents, devices, plans, IP pools, notification templates, and approved integrations. A market remains an operational subdivision inside a tenant, never a substitute for tenant isolation.

Out of scope for the initial production release are autonomous router configuration pushes, direct management of every hardware vendor, unreviewed AI actions, full general ledger accounting, field technician mobile applications, and public partner APIs without approved contracts. These remain visible in the roadmap so they are designed consistently from the beginning.

4. Current implementation evidence and gap assessment

Verified in the active repository: Next.js 16, React, TypeScript, Convex, WorkOS libraries, router, access-point and switch registries, collector-run records, telemetry tables, role-aware screens, audit-log surfaces, platform and dashboard routes, and a LAN-local RouterOS collector pattern. Router credentials are intended to remain server-side, and collector status is recorded without exposing credentials to the browser. Existing UI and server code are platform and market scoped rather than universally tenant scoped.

Historically verified but requiring a fresh release-specific check: WorkOS callback recovery, membership synchronization, router and access-point CRUD, credential migration tooling, selected production deployments, and existing build/test gates. These are not proof of a current multi-tenant production release. Fresh authenticated WorkOS testing, cross-tenant denial testing, a real LAN collector sample, signed Centipid-provider validation, finance acceptance, and full automated authorization coverage remain required.

Known transition gaps: current WorkOS code centers a configured platform organization; many data records lack tenantId; the collector uses a shared-secret pattern that must be replaced by per-connector mTLS; RADIUS AAA, subscriber service lifecycle, tenant onboarding, tenant-scoped billing, Postgres RLS, HA nodes, and a subscriber portal are not established in the active dashboard. Centipid payload and reconciliation semantics remain provider-contract dependent and must not be inferred.

5. Multi tenant architecture and data isolation

The target is one shared application backend, one shared RADIUS and worker estate, and strict logical tenant isolation. Every tenant-owned entity carries tenantId directly: organizations, memberships, markets, sites, subscribers, contacts, services, credentials, devices, NAS clients, routers, access points, switches, policies, sessions, accounting events, invoices, payments, vouchers, jobs, files, notifications, integrations, imports, audit events, and telemetry. Redundant tenantId is intentional because it enables simple indexes, queue validation, audit filtering, and defense in depth.

The server resolves the tenant from the hostname and the authenticated WorkOS organization membership. Browsers may provide an identifier only as a route reference; they never establish authority by sending a tenantId. Every query, mutation, HTTP route, worker job, webhook, export, object-storage URL, and audit query validates the resolved tenant and capability. Platform and Network roles operate only in their protected MylesNet organizations and use explicit audited elevation when acting for a tenant.

Convex remains the real-time SaaS workflow store for tenant provisioning, membership mirrors, operational views, subscriber records, invoices, entitlement state, audit trails, and user experience. PostgreSQL is the authoritative relational store for RADIUS policy, authentication/accounting events, quota calculation, finance-grade ledgers, and high-integrity relationship constraints. PostgreSQL row-level security is enabled for tenant tables; each transaction sets a verified tenant context, and privileged service accounts are separately controlled.

6. In place transition and cutover controls

Conversion starts with an inventory and schema classification. Each existing table and integration is labelled global, platform-scoped, tenant-owned, obsolete, or unknown. The initial MylesNet tenant is created and the current estate is attached only after counts, references, permissions, storage objects, device records, and audit history reconcile. No record is silently assigned when its owner cannot be determined; ambiguous records enter a review queue.

The migration sequence is additive first: introduce tenant, organization, tenant membership, entitlement, and tenantId fields; create composite tenant indexes; backfill in bounded batches; validate row counts and foreign-key relationships; enforce read paths; then enforce write paths. Database backups, export manifests, migration run IDs, reversible feature flags, and a measured rollback procedure are required before each enforcement checkpoint. The first irreversible checkpoint is delayed until full tenant-scoped reads, writes, worker jobs, and user authorization tests pass.

Cutover runs in supervised maintenance windows. The cutover checklist includes completed data reconciliation, role verification in WorkOS and Convex, connector credential rotation, RADIUS client validation, smoke tests for payment-to-entitlement flow, monitoring, incident ownership, rollback time limit, and written sign-off. The old platform-wide collector secret is retired only after all active connectors have a validated mTLS identity.

7. Panel and route architecture

The mandatory panel names are Platform, Admin, Agency, Reseller, Partner, and Dashboard. Routes use /platform, /admin, /agency, /reseller, /partner, and /dashboard only. Forbidden variants such as master-admin, super-admin, tenant-app, and similar names are not used in code, routes, folders, documentation, or audit records. Panel hostnames follow admin.<product-domain>, network.<product-domain>, agency.<product-domain>, reseller.<product-domain>, partner.<product-domain>, and .<product-domain>.

Platform is the MylesCorp control plane: ISP tenant provisioning, lifecycle, SaaS subscriptions, manual invoices, feature entitlements, platform communications, support grants, security, global audit, analytics, and health. Admin is MylesCorp network operations: shared RADIUS nodes, NAS clients, connector health, queues, accounting, CoA delivery, worker jobs, availability, capacity, incident coordination, and infrastructure settings. It is not a tenant NOC console.

Dashboard is the tenant workspace: tenant setup, staff, sites, network inventory, routers, access points, connectors, RADIUS policies, subscribers, services, invoices, payments, vouchers, agents, support, reports, audit, and settings. Dashboard/portal is a subscriber-only layout for service status, usage, invoices, payments, receipts, devices, tickets, and profile. Reseller launches with customer acquisition, assigned subscriber management, voucher sales, commission, settlement, and limited reports. Agency and Partner remain schema-aware but feature-flagged.

8. WorkOS identity and authorization

WorkOS AuthKit is the only authentication provider. The WorkOS Management MCP is required for WorkOS organization, role, webhook, JWT-template, and membership mutations. The previous Auth0 subscriber portal concept is rejected. Subscriber portal identities are modeled in WorkOS with a separate subscriber application and role boundaries so that subscriber identities cannot reach staff panels.

Three WorkOS scopes are used. MylesNet Platform contains platform-owner, platform-admin, and platform-support roles. MylesNet Network contains network-owner, network-admin, network-operator, and controlled operations roles. Each ISP tenant has a tenant organization with tenant-admin, NOC, finance, sales, reseller, viewer, and approved custom tenant roles. WorkOS establishes organization membership and baseline role. Convex owns detailed permission grants, site scope, market scope, module entitlements, support grants, and operation-level authorization.

Tenant staff normally belong to one ISP tenant only. Cross-tenant membership is restricted to approved partners, resellers, or agencies with explicit scope. MylesCorp support receives a time-bound, reason-coded, audited support grant rather than permanent tenant membership. WorkOS webhook events map only known organizations; unknown organization events are quarantined. Deactivation revokes membership and application access. Optional per-tenant SSO and SCIM are enabled only after domain and support readiness checks.

9. Tenant onboarding and readiness wizard

Platform staff create a tenant record, select country, timezone, base currency, service plan and device/site limits, assign the tenant hostname, and issue the first owner invitation. The tenant becomes commercially active after platform provisioning but application modules remain gated by a readiness checklist. If an invitation expires, the tenant is not deleted; Platform may resend or replace the owner invitation with an audited action.

The tenant wizard captures legal display name, branding, support contacts, market and site structure, tax settings, payment collection model, provider configuration, staff, notification preferences, service-plan catalogue, and first network site. It shows dependency status for WorkOS membership, DNS, connector, RADIUS client, payment sandbox, messaging provider, imports, and go-live approval. Settings have drafts, validation, change history, and role-controlled approval where risk requires it.

CSV onboarding uses published templates, schema validation, duplicate detection, dry-run counts, error export, reviewer approval, idempotent import run IDs, reconciliation, and an immutable audit trail. Imports cover subscribers, services, invoices, opening balances, routers, access points, agents, vouchers, and permitted historical data. A failure never creates a partially trusted result; the run is recoverable or reverted as one tracked operation.

10. Device, NAS, router and access point onboarding

Each tenant installs an outbound edge connector on an approved LAN host. The connector authenticates with mTLS using a tenant- and connector-scoped certificate, polls or receives jobs from the platform, and exposes no inbound management port. It can read RouterOS, SNMP, Syslog, and approved vendor APIs, normalize health and inventory data, and submit signed results. Certificates, connector versions, scopes, rotation dates, last check-in, and revocation status are auditable.

The router wizard has Monitoring and RADIUS-ready modes. It tests reachability, TLS trust, permissions, clock, management-path safety, and device identity. It generates configuration templates for review, including RADIUS clients, accounting interim updates, PPPoE or Hotspot profiles, CoA, IP pools, and firewall guidance. The platform does not issue unattended router configuration pushes at launch. Production changes require a reviewed template, tenant approval when appropriate, and two-person approval for high-risk changes.

Access-point onboarding supports vendor adapters for MikroTik, Ubiquiti, Cambium, TP-Link, Aruba, Ruckus, and future devices, with SNMP fallback. Discovery results are reviewed before approval; approved devices inherit tenant, site, router, switch-port, telemetry, alert, and retention controls. Configuration drift, configuration backups, health, signal or interface statistics where available, and incidents are recorded without exposing management credentials to browsers.

11. RADIUS AAA and service policy

FreeRADIUS 3.x runs as a separate private service. It authenticates and authorizes PPPoE and MikroTik Hotspot first, with room for MAC authentication, vouchers, enterprise 802.1X, IPoE/DHCP, fixed wireless, FTTH, VPN, and wholesale models. It receives policy data from PostgreSQL through a tightly scoped service account and emits accounting and operational events through durable ingestion. Browser applications never directly call router or RADIUS administration interfaces.

Policies are versioned objects separate from subscribers. A policy can define credentials, speed and burst profiles, concurrent sessions, device limits, data/time quotas, fair-use thresholds, VLAN, IPv4/IPv6, IP pools, static IP, DNS, schedules, idle and session timeout, firewall profile, and service status. Entitlement evaluation combines active service, policy version, finance state, suspension reason, grace period, and approved exception. Historical sessions and invoices retain the policy version and currency context that applied at the time.

Accounting accepts Start, Interim-Update, and Stop events; correlates session identifiers; records NAS, port, framed address, MAC, bytes, timestamp, cause, and source; deduplicates packets; detects counter rollover, missing Stops, late packets, NAS restarts, and stale sessions. Operational staff can view active, stale, failed, and terminated sessions and issue controlled CoA or Disconnect Requests. All actions are scoped, rate-limited, auditable, and verified.

12. Availability, security and abuse controls

RADIUS is deployed as regional active-active nodes with health checks, replicated policy access, local authorization cache where safe, queued accounting, retries, dead-letter queues, clock synchronization, and a documented degraded-mode policy. The launch objective is 99.95 percent availability, RPO of 15 minutes, and RTO of four hours. The AWS Cape Town region is primary; backups, point-in-time recovery, runbooks, restore tests, and a documented disaster-recovery location are required before claiming the objective.

Security controls include TLS in transit, encryption at rest, KMS-backed secrets, per-connector certificates, RADIUS client restrictions, RadSec as the preferred transport, VPN fallback, MFA and session controls through WorkOS, least-privilege RBAC, IP allowlists where justified, CSRF protection, rate limits, signed webhooks, idempotency, audit trails, vulnerability scanning, dependency scanning, secret scanning, container scanning, key rotation, and incident response procedures.

Fraud and abuse controls identify repeated authentication failure, abnormal concurrent sessions, credential sharing, MAC churn, suspicious payments, voucher reuse, unusual usage, impossible travel where reliable inputs exist, and abnormal NAS behavior. Controls produce explainable alerts and review queues. Automatic suspension is limited to approved deterministic rules; model predictions or ambiguous signals cannot change access without a defined authorization policy and an auditable review path.

13. Subscriber lifecycle and self service

A subscriber is a unified account that can represent a person, household, business, school, hotel, government client, or wholesale account. It supports multiple contacts, locations, services, credentials, devices, KYC documents where approved, contracts, notes, consent, communications, support cases, and a chronological timeline. Duplicate detection and account merge are controlled operations with preserved history.

Service lifecycle states cover draft, pending activation, active, grace, suspended, expired, blocked, terminated, reconnection pending, and failed provisioning. Creation, payment, plan change, pause, resume, suspension, expiry, and termination emit durable events. A high-risk enterprise change may require approval. Provisioning failures are explicit and recoverable; they never silently claim an active service.

The subscriber portal is mobile-first and uses a separate Dashboard/portal layout. It explains the current service state, restriction reason, amount due, and next action. It provides usage and session history, invoices, receipts, verified payments, plan options, device management, contact updates, vouchers, tickets, announcements, and communication preferences. It does not expose staff, infrastructure, raw accounting, provider secrets, or cross-subscriber information.

14. Billing, payments and revenue control

MylesNet separates MylesCorp SaaS billing from ISP subscriber billing. Platform manages a tenant subscription, plan entitlements, manual SaaS invoices, payment status, suspension policy, and support. The tenant manages subscriber services, invoices, tax, discounts, vouchers, wallets where approved, adjustments, refunds, credit and debit notes, and customer payment communications. Financial records retain immutable amount, ISO currency, exchange-rate snapshot when used, source, actor, and references.

Direct M-Pesa Daraja is the first subscriber-payment adapter. Tenant-owned collection sends funds to the ISP merchant account. Managed collection is a separate, compliance-gated model with a settlement ledger, fee policy, payout schedule, reconciliation, exception handling, and legal review. The provider adapter model accommodates Airtel Money, cards, bank transfer, regional aggregators, and other rails only after commercial, sandbox, webhook, and security approval.

A payment initiates as pending. Service changes happen only after verified callback or authoritative provider status confirmation, matching amount and reference, idempotency validation, invoice or wallet reconciliation, ledger posting, and entitlement update. The system then creates a network job, performs CoA or Disconnect if needed, confirms the outcome, records exceptions, and sends a notification. Reversals, refunds, disputes, duplicates, delayed callbacks, and reconciliation mismatches have explicit states and do not create duplicate entitlement or ledger changes.

15. Support, communication, reporting and APIs

Support includes tenant and portal ticket creation, categories, priority, assignment, SLA timers, internal notes, attachments, escalation, knowledge articles, service history, and satisfaction capture. Authorized staff can see relevant payment, service, session, policy, and device context without receiving raw infrastructure secrets. Portal, email, SMS, WhatsApp, and approved integrations are ingested through validated channels with clear identity correlation.

Notifications support tenant-selected SMS and email adapters at launch, with WhatsApp and push behind provider approval. Templates include variables for subscriber, invoice, payment, expiry, ticket, and maintenance events. Delivery status, retries, suppression, opt-out consent, rate controls, segmentation, provider failover policy, and tenant-safe sender identity are retained. No provider is declared live without an approved contract and verified signed delivery flow.

Reports cover active subscribers, registrations, renewals, churn, plan performance, revenue, payment success, aging, gateway reconciliation, session use, authentication failures, NAS health, CoA success, voucher sales, agent commission, ticket SLA, and customer lifetime value. External APIs are versioned REST and OpenAPI contracts with OAuth or scoped machine credentials, tenant isolation, pagination, filtering, idempotency, rate limits, tracing, structured errors, and signed webhooks. Events include subscriber, service, payment, invoice, session, router, and ticket lifecycle notifications.

16. Production technology stack and deployment boundaries

The codebase transitions to a pnpm Turborepo with separate deployable panel apps: apps/admin for Platform, apps/network for Admin, apps/web for Dashboard and portal, and apps/reseller for Reseller. Agency and Partner apps are created only when their modules are enabled. Shared packages include UI, schemas, types, API contracts, configuration, and email templates. The frontend uses Next.js, React, TypeScript, Tailwind CSS, shadcn/ui, Radix UI, React Hook Form, Zod, TanStack Query and Table, ECharts, and later MapLibre.

Vercel hosts web applications. Cloudflare provides wildcard DNS, TLS, WAF, DDoS defense, and edge rate limiting. AWS Cape Town hosts private network workloads: ECS Fargate for FreeRADIUS and Go workers, RDS PostgreSQL Multi-AZ, ElastiCache Redis, SQS/EventBridge/DLQ, S3, Secrets Manager, KMS, CloudWatch, managed Prometheus and Grafana. OpenTelemetry instruments all services and Sentry tracks application errors. Terraform controls infrastructure and GitHub Actions runs test, build, security, migration, and deployment gates.

TimescaleDB or ClickHouse are introduced only when PostgreSQL partitioning and measured accounting or analytics workloads justify them. Temporal is introduced only for workflow complexity that cannot be safely handled by durable queue jobs and explicit compensation. Expo mobile applications, fiber GIS, IPAM, field workforce, AI assistance, and predictive analytics are deferred until the core AAA, billing, and operations flows have evidence of reliability.

17. Data governance, observability and operations

Data governance defines tenant ownership, lawful processing, consent, retention, export, deletion, KYC access, financial retention, audit retention, regional residency disclosure, document-storage controls, and restore procedures. Sensitive records are minimized, encrypted, access-logged, and exposed only through roles with a business need. Tenant deletion follows a documented legal and commercial retention workflow rather than a direct hard delete.

Observability tracks RADIUS authentication latency and failure cause, accounting packet loss, CoA delivery, active-session accuracy, NAS availability, connector check-in, worker completion, payment callback delay, reconciliation exceptions, provisioning completion, notification delivery, API latency, queue depth, database health, cost, and security events. Dashboards distinguish platform-wide operations from tenant views. Alert routing respects tenant boundaries and maintenance windows, with incident history and ownership.

Operating runbooks cover tenant onboarding, WorkOS role and membership changes, support elevation, payment outages, RADIUS node failure, accounting backlog, connector compromise, certificate rotation, router change review, provider webhook failures, data restore, security incidents, and planned maintenance. Each runbook names an owner, evidence required, escalation path, rollback point, and post-incident review record.

18. Delivery phases, tests and release gates

Phase 0 establishes repository governance, design assets, CI, environments, DNS plan, secret policy, and the transition inventory. Phase 1 adds tenant schema, tenantId backfill, indexes, PostgreSQL foundation, and isolation tests. Phase 2 replaces single-platform identity assumptions with the three-scope WorkOS model, secure session handling, and RBAC. Phase 3 delivers core tenant, subscriber, service, policy, and audit functions. Phase 4 delivers payment sandbox and notification contracts. Phase 5 builds shared UI. Phase 6 delivers the launch panels and onboarding wizards. Phase 7 delivers RADIUS, connectors, routers, accounting, CoA, and HA. Phase 8 completes infrastructure and production observability. Phase 9 is the launch audit and controlled cutover.

The test strategy includes unit tests for validation and domain transitions, integration tests for Convex and PostgreSQL isolation, WorkOS webhook and membership tests, contract tests for workers and payment callbacks, RADIUS lab tests for PPPoE and Hotspot, failure injection for accounting and queues, Playwright role and tenant tests, accessibility tests, security tests, load tests, backup restore tests, and disaster-recovery exercises. A tenant A identity must never read, mutate, export, receive a webhook for, or observe tenant B data.

Production release is blocked until tenant isolation, WorkOS role/membership synchronization, valid callback and webhook signatures, RADIUS failover, payment idempotency, accounting reconciliation, backup restore, alert ownership, change approvals, documented rollback, and authenticated browser verification all pass. Build success alone is not a release criterion. The final acceptance report records exact environments, evidence, known limitations, and owner sign-off.

19. Risks, dependencies and final summary

Primary risks are tenant data leakage, incorrect identity mapping, payment entitlement errors, router reachability limits, incomplete provider contracts, RADIUS availability, accounting accuracy, managed-collection compliance, migration error, and unsupported vendor behavior. The mitigation is not a generic promise: each risk is addressed by a concrete tenant guard, WorkOS mapping rule, idempotent state machine, connector architecture, provider sandbox gate, HA test, reconciliation control, legal approval, rollback checkpoint, or vendor adapter capability record.

Dependencies requiring explicit approval or evidence are the final product domain, AWS account and network design, Vercel and Cloudflare projects, WorkOS Management MCP authentication, exact organization IDs configured without embedding secrets, M-Pesa Daraja business and sandbox access, messaging/email provider contracts, RADIUS node sizing, certificate authority and VPN approach, data-retention and managed-collection compliance, first tenant data, and network lab hardware. No credentials, identifiers, or provider semantics are invented in this specification.

MylesNet v3 provides the integrated production path from the existing dashboard to a true multi-tenant ISP and RADIUS SaaS. It preserves useful router and operations work, corrects the single-platform boundary, adds rigorous tenant isolation and workflow controls, and sequences full ISP capability behind verified operational foundations. The immediate next engineering action is the Phase 0 transition inventory and the Phase 1 tenant schema checkpoint, followed by the WorkOS organization and authorization conversion.

20. Detailed functional module catalogue

Tenant and organization administration

Platform can create, read, update, suspend, reactivate, archive, and export tenant records. Tenant administrators can read their own organization and update only tenant-owned profile, brand, country, timezone, currency, tax, support contact, notification, and feature settings allowed by entitlement. Every lifecycle change requires a reason, actor, timestamp, prior state, new state, and audit record. Tenant deletion is never a direct delete; it begins a retention and legal workflow.

Subscriber CRM

Authorized tenant users can create, read, update, merge, suspend, restore, and export subscriber accounts within their tenant. Each subscriber supports contacts, addresses, KYC evidence where approved, subscriber type, consent, notes, tags, communications, linked devices, multiple services, account timeline, duplicate detection, and controlled merge. Sales can create and update prospects and subscriber records within assigned scope; Finance cannot edit technical credentials; NOC cannot alter invoices or financial adjustments without finance permission.

Service, plan, credential, and entitlement management

Tenant administrators and approved NOC users manage reusable service plans, policy versions, speed profiles, quota profiles, device limits, access schedules, IP pools, service templates, credentials, and service lifecycle. A plan update creates a new version when policy behavior would change. Subscriber service actions support create, read, update, activate, pause, resume, upgrade, downgrade, suspend, terminate, and view history. Credential reveals are prohibited; resets create audited replacement credentials and provisioning jobs.

Network inventory and assurance

Tenant NOC can create, read, update, archive, and view approved routers, NAS clients, access points, switches, IP pools, connectors, sites, uplinks, configuration templates, telemetry, incidents, and maintenance windows within tenant scope. Only Platform or Admin can create shared RADIUS nodes and platform infrastructure. Tenant operators may request reviewed configuration templates but cannot directly run unmanaged device commands. Archived inventory is hidden from active operation while preserving history and relationships.

Commercial operations

Finance can create, read, update, issue, void, credit, debit, reconcile, and export subscriber invoices, payments, tax settings, discounts, refunds, wallets where enabled, settlement records, receipts, and aged-debt reports. Sales and Reseller users can create vouchers and sales records only within granted plan, customer, territory, commission, and credit limits. Payment provider callbacks are machine actions only and cannot be manually simulated through UI routes. Every monetary event is immutable or corrected by a compensating entry.

Support, messaging, reporting, and governance

Staff can create, read, update, assign, escalate, resolve, reopen, and export tickets according to role and tenant scope. Messaging supports templates, campaigns, transactional events, consent, delivery status, suppression, and audit. Reports are read and export scoped, with saved reports and scheduled delivery restricted by role. Audit events, authentication records, support grants, retention actions, and security alerts are readable only by their respective tenant or platform security roles and are never editable or deletable by normal users.

21. RBAC permissions and scope matrix

Platform owner has complete platform governance including tenant lifecycle, platform roles, SaaS billing, feature flags, security posture, support grants, global audit, irreversible retention approvals, and platform configuration

Platform admin manages day-to-day tenants, billing operations, support, and platform communications but cannot alter protected owner assignments or security-root settings. Platform support has read-only operational visibility plus explicitly granted tenant support sessions and ticket handling. All platform roles are denied direct tenant financial edits and tenant infrastructure access unless a time-bounded support grant and capability permit it.

Network owner and network admin manage shared RADIUS nodes, NAS client trust, RadSec/VPN policy, worker deployments, queues, accounting ingestion, health, capacity, and incident response

Network operator can inspect and execute bounded operational procedures such as approved CoA or Disconnect delivery, job retries, and health acknowledgement. Network roles do not receive tenant subscriber, invoice, payment, KYC, or broad CRM access merely by belonging to the Network organization. Access is filtered to the operational objects and audit fields required for the task.

Tenant admin controls tenant configuration, staff invitations, local roles, sites, plans, subscribers, services, billing settings, network inventory, and tenant reporting subject to subscription entitlements

NOC manages routers, connectors, NAS assignment, policies, sessions, service provisioning, incidents, and approved technical changes. Finance manages invoices, payments, reconciliation, receipts, adjustments, taxes, and finance reports. Sales manages prospects, subscriber acquisition, assigned offerings, vouchers, and commissions. Viewer is read-only and has no credential, financial, security, or export access unless a separate permission is granted.

Reseller access is explicitly delegated by tenant and never implied by a panel

A reseller can view and manage only assigned customers, sell permitted vouchers or plans, view assigned commissions and settlements, and use limited reports. It cannot view NAS credentials, shared RADIUS infrastructure, tenant-wide financial data, unassigned subscriber records, or tenant settings. Agency and Partner roles are disabled until their feature flags, data contracts, commercial model, and scope boundaries pass approval.

Permission checks are server-side and action-specific

Representative permissions are tenants.manage, memberships.manage, subscribers.read, subscribers.manage, services.manage, policies.manage, sessions.read, sessions.disconnect, radius.coa, devices.read, devices.manage, connector.manage, invoices.read, invoices.manage, payments.reconcile, vouchers.issue, tickets.manage, communications.send, reports.export, audit.read, security.manage, and support.grant. UI visibility follows these permissions but never replaces a server authorization check.

22. Data domain and tenant ownership inventory

Identity domain: users, WorkOS identities, organization memberships, roles, permissions, sessions, MFA posture, invitations, support grants, service accounts, API credentials, authentication events, and access reviews

Tenant-owned identity records carry tenantId; Platform and Network organization records are protected global control-plane records. WorkOS external IDs, membership IDs, role IDs, creation times, revocation times, synchronization status, and audit correlation IDs are retained without storing authentication secrets.

Commercial domain: tenants, subscriptions, plan entitlements, tenant SaaS invoices, subscriber accounts, contacts, addresses, services, service plans, policy versions, credentials, invoices, invoice lines, tax rules, discounts, payments, payment intents, provider callbacks, ledger entries, refunds, settlements, vouchers, voucher batches, agents, commissions, payout records, opening balances, currencies, exchange-rate snapshots, and reconciliation runs

Financial records are append-only or corrected through compensating entries and retain tenantId and immutable currency context.

Network domain: sites, markets, routers, NAS clients, access points, switches, connectors, connector certificates, management paths, vendor adapters, policy profiles, IP pools, IP assignments, VLANs, RADIUS clients, RADIUS nodes, configuration templates, change requests, approvals, backups, drift snapshots, maintenance windows, incidents, and device health

Shared RADIUS node records are platform-owned; tenant NAS and device objects always include tenantId and site scope.

AAA and telemetry domain: authentication attempts, authorization decisions, accounting Starts, Interim Updates, Stops, sessions, session usage, quota counters, fair-use actions, CoA requests, Disconnect requests, NAS health, worker jobs, queue attempts, failure reasons, collector samples, normalized telemetry, alert events, and operational metrics

Accounting tables are partitioned and tenant filtered; raw packet content and secrets are minimized. Every state transition includes source, correlation ID, timestamp, and idempotency key where applicable.

Collaboration and governance domain: tickets, ticket messages, internal notes, attachments, notification templates, deliveries, campaigns, consent, audit events, exports, import runs, retention holds, deletion requests, legal approvals, incident records, runbook executions, feature flags, and configuration versions

File metadata carries tenantId, classification, retention, malware scan state, signed URL authorization, and access audit. Object storage keys are tenant-prefixed and are authorized by server-side scope checks.

23. End to end workflows and state machines

Tenant provisioning workflow: Platform validates commercial approval; creates tenant and entitlement records; creates or links the tenant WorkOS organization; creates the owner invitation; assigns hostname; creates readiness checklist; records audit evidence; and sends onboarding communication

Owner acceptance establishes tenant membership and opens the wizard. Failure compensation deactivates incomplete records or marks them for safe review; it never leaves an active tenant with unknown ownership.

Subscriber activation workflow: authorized staff or import creates subscriber and service in draft; validation confirms plan, identity, site, payment rule, credential and network dependencies; approved activation creates an entitlement and durable provisioning job; worker and RADIUS policy result are recorded; CoA or Disconnect is issued only when required; verification updates service state; notification is sent

Failed steps enter actionable failed-provisioning state with retry, rollback, and manual resolution options.

Payment-to-access workflow: payment intent is created; provider callback is signature-verified; amount, currency, tenant, invoice or service reference, timestamp, and idempotency key are validated; payment and immutable ledger entry are posted; reconciliation allocates funds; entitlement changes; a network job applies access policy; session action is verified; receipt and notification are delivered

Duplicate, delayed, reversed, disputed, or mismatched callbacks are retained as explicit exceptions and cannot create duplicate service activation.

Support and incident workflow: event, portal user, staff member, email, or approved channel opens a ticket or incident; identity and tenant are resolved; severity and SLA are applied; assignment, internal notes, customer communication, escalation, maintenance link, resolution, reopening, and satisfaction are tracked

NOC can inspect tenant-scoped session and device context; only permitted users can initiate controlled RADIUS actions; support actions create audit events and do not expose secret data.

Access revocation workflow: a membership is disabled in WorkOS; webhook and application mirror update; sessions and scoped tokens are revoked; queued jobs are revalidated at execution; portal and staff routes deny access; audit record is written

Tenant suspension preserves records but blocks tenant mutations, new sessions, provider initiation, and connector commands according to the suspension policy while retaining limited payment and recovery paths.

24. API, webhook and worker contract requirements

Public and partner APIs use versioned REST routes documented by OpenAPI

Each route has tenant resolution, authentication, scoped authorization, request validation, pagination, filtering, sorting, rate limits, trace ID, structured error code, idempotency behavior for mutations, and audit classification. APIs are disabled by default per tenant and use scoped OAuth machine credentials or approved API keys; no browser session cookie is reused as an integration credential.

Webhook consumers support WorkOS lifecycle events, payment provider callbacks, messaging delivery callbacks, and approved partner events

Every event is signature-verified, stored with source and delivery ID, deduplicated, tenant-resolved through an approved mapping, processed asynchronously, retried with bounded policy, and sent to a dead-letter queue when exhausted. Unknown organization, tenant, signature, or payload mappings are quarantined for review and never create users, payments, or entitlements automatically.

Worker jobs are immutable contracts containing job type, tenantId when tenant-owned, object references, requester, capability requirement, correlation ID, expiry, idempotency key, expected configuration version, and safe response schema

Workers authenticate with service identities, retrieve secrets only from managed storage, validate job scope at execution, return normalized result, and cannot bypass policy through client-provided URLs or credentials. Network actions support dry-run and verified completion states.

Required event names include tenant.provisioned, tenant.suspended, subscriber.created, service.activated, service.suspended, payment.succeeded, payment.failed, payment.reversed, invoice.overdue, session.started, session.stopped, quota.thresholdReached, router.offline, connector.revoked, ticket.created, and ticket.resolved

Event delivery is best effort only for external consumers; internal state changes remain transactionally durable before publication.

25. Detailed acceptance criteria and operational controls

CRUD acceptance requires every create, read, update, archive, restore, export, and irreversible action to demonstrate validation, authorization, tenant scope, audit logging, pagination where applicable, safe error behavior, and role-specific UI control

Delete operations default to archive or retention workflow. Tests cover owner, administrator, restricted role, disabled user, tenant suspension, cross-tenant actor, platform support grant, and unauthenticated caller.

RBAC acceptance requires a role-to-permission registry, WorkOS membership mapping, Convex authorization tests, user-interface visibility tests, and negative tests proving an unauthorized role cannot call a hidden mutation directly

Every role assignment and permission escalation is auditable. Role changes have approval and session-refresh behavior. Custom tenant roles can use only the approved permission catalog, have immutable slugs, and cannot grant platform or Network capabilities.

Network acceptance requires RADIUS lab evidence for PPPoE and MikroTik Hotspot, RadSec or VPN transport validation, NAS client restriction, accounting Start/Interim/Stop behavior, stale session handling, CoA and Disconnect reliability, policy version accuracy, quota enforcement, connector mTLS rotation, worker retry, and active-active failover

No live router change is released without target confirmation, approved template, backup or rollback evidence, and two-person approval where classified high risk.

Financial acceptance requires M-Pesa sandbox proof, verified callback signatures, idempotent repeated callback tests, allocation and reconciliation checks, reversal behavior, currency snapshot checks, receipt accuracy, service activation confirmation, provider outage handling, settlement controls for managed collection, finance-only adjustment permissions, and export consistency

No payment provider moves to production without merchant authorization, webhook contract, fraud controls, and operational ownership.

Launch acceptance requires a production readiness review: infrastructure as code, secret rotation, container and dependency scanning, security tests, performance and queue-capacity tests, backup restore, disaster-recovery exercise, observability dashboards, alert routing, incident runbooks, accessibility review, support training, data migration reconciliation, authenticated browser tests, and signed owner approval

Results are recorded with environment, time, evidence, limitation, owner, and remediation status.

A. Appendix A Status legend

Label	Meaning
Verified	Observed in the active repository or through current evidence; it remains subject to release-specific validation.
Historically verified	Previously tested or deployed but not reconfirmed for this release.
Unverified	A stated or observed condition lacking current end-to-end evidence.
Planned	A committed target design that has not been implemented.
Approval gated	Requires a provider contract, commercial decision, security review, legal review, or explicit owner approval before activation.

B. Appendix B Acceptance checklist

Acceptance area	Minimum evidence
Tenant isolation	Cross-tenant read, write, export, queue, webhook and storage denial tests.
Identity	Authenticated WorkOS organization, role, revocation, support-grant and portal boundary tests.
Network and AAA	PPPoE and Hotspot lab tests, accounting, CoA, Disconnect and RADIUS failover validation.
Payments	Sandbox callback signature, idempotency, reversal, reconciliation and entitlement verification.
Operations	Alert ownership, backup restore, DR exercise, connector rotation, rollback rehearsal and runbook sign-off.